

Lab 3 — INC-0134 — The Compromised Identity

Service Principal · Key Vault · Conditional Access · Entra ID

ENVIRONMENT

Resource Group	lab3-rg
Key Vault	lab3-kv-tr2zcmzzlno4
Service Principal	lab3-webapp-sp (AppId: b92f3eb3-4734-4882-be8c-25a4bfd5e801)
Location	canadacentral
Tools	PowerShell · Azure CLI · Entra Admin Center

PHASE 1 — DEPLOY

1

Get Object ID and Tenant ID

PASS

```
# Required parameters for Bicep deployment
az ad signed-in-user show --query id -o tsv
az account show --query tenantId -o tsv
```

2

Create Resource Group and Deploy Bicep

PASS

```
az group create --name lab3-rg --location canadacentral

az deployment group create `
  --resource-group lab3-rg `
  --template-file main.bicep `
  --parameters currentUserObjectId="e895eale-..." tenantId="df38f0dd-..."
  --name lab3-deployment
```

3

Get Key Vault Name and Run Setup Script

PASS

```
az keyvault list --resource-group lab3-rg --query "[].name" -o tsv

.\setup.ps1 -KeyVaultName "lab3-kv-tr2zcmzzlno4" -ResourceGroupName "lab3-rg"
```

```
[LAB 3] Setting up broken identity environment...
[1/4] Service Principal created: lab3-webapp-sp (AppId: b92f3eb3-...)
WARNING: Owner role assigned at subscription scope (this is the bug)
[2/4] Credentials written to sp-credentials.txt (insecure!)
[3/4] SP granted ALL permissions on Key Vault (this is the bug)
LAB 3 SETUP COMPLETE - Three security problems are now live.
```

PHASE 2 — DIAGNOSE · PROBLEM 1: OVER-PRIVILEGED SP

4

Check All Role Assignments for Service Principal

PROBLEM

```
# Key diagnostic command - --all shows across ALL scopes
az role assignment list `
  --assignee "b92f3eb3-4734-4882-be8c-25a4bfd5e801" `
  --all `
  --query "[].{Role:roleDefinitionName, Scope:scope}" `
  -o table
```

Role	Scope
Owner	/subscriptions/98104e29-af5e-4ff5-9f16-be7c8f83f2b0

 PROBLEM CONFIRMED

Owner at subscription scope. A web app only needs to read one Key Vault secret. Owner = full admin over entire subscription. Massive blast radius if credentials are compromised.

PHASE 3 — FIX · PROBLEM 1: OVER-PRIVILEGED SP

5

Remove Owner Role at Subscription Scope

PASS

```
az role assignment delete `
  --assignee "b92f3eb3-4734-4882-be8c-25a4bfd5e801" `
```

```
--role "Owner" \  
--scope "/subscriptions/98104e29-af5e-4ff5-9f16-be7c8f83f2b0"
```

6 Assign Least Privilege — Key Vault Secrets User Only

PASS

```
$kvId = az keyvault show -g lab3-rg -n "lab3-kv-tr2zcmzyzzlno4" --query id  
-o tsv  
  
az role assignment create \  
  --assignee "b92f3eb3-4734-4882-be8c-25a4bfd5e801" \  
  --role "Key Vault Secrets User" \  
  --scope $kvId
```

7 Verify SP Role Fix

PASS

```
az role assignment list \  
  --assignee "b92f3eb3-4734-4882-be8c-25a4bfd5e801" \  
  --all \  
  --query "[].{Role:roleDefinitionName, Scope:scope}" \  
  -o table
```

Role	Scope
Key Vault Secrets User	/subscriptions/.../resourceGroups/lab3-rg/.../lab3-kv-...

✓ CONFIRMED OK

Owner gone. Key Vault Secrets User assigned at Key Vault scope only. SP has minimum required permissions.

PHASE 4 — DIAGNOSE · PROBLEM 2: KEY VAULT MISCONFIG

8 Check Key Vault Security Settings

PROBLEM

```
az keyvault show \  
  --name "lab3-kv-tr2zcmzyzzlno4" \  
  --resource-group lab3-rg
```

```
--query "{RBAC:properties.enableRbacAuthorization,
PurgeProtection:properties.enablePurgeProtection,
NetworkDefault:properties.networkAcls.defaultAction,
SoftDeleteDays:properties.softDeleteRetentionInDays}" `
-o table
```

RBAC	PurgeProtection	NetworkDefault	SoftDeleteDays
False	True	Allow	7

❑ PROBLEM CONFIRMED

RBAC: False (using legacy Access Policies). NetworkDefault: Allow (open to internet). SoftDeleteDays: 7 (too short — should be 90). Three separate security misconfigurations.

PHASE 5 — FIX · PROBLEM 2: KEY VAULT MISCONFIG

9 Enable RBAC Authorization

PASS

```
az keyvault update `
--name "lab3-kv-tr2zcmzyzzlno4" `
--resource-group lab3-rg `
--enable-rbac-authorization true
```

10 Lock Down Network Firewall

PASS

```
az keyvault update `
--name "lab3-kv-tr2zcmzyzzlno4" `
--resource-group lab3-rg `
--default-action Deny `
--bypass AzureServices
```

11 Soft Delete Retention — Deployment-Time Finding

INFO

Attempted to update soft delete retention to 90 days:

```
az keyvault update --name "lab3-kv-tr2zcmzyzzlno4" --resource-group lab3-rg
--retention-days 90
```

(BadRequest) The property "softDeleteRetentionInDays" has been set already and it cannot be modified.

❑ **PROBLEM CONFIRMED**

Azure does not allow changing soft delete retention after creation. This is a deployment-time setting. Fix: Set to 90 days in Bicep before deploying. Document as finding for next deployment cycle.

12 Verify Key Vault Security Fix

PASS

```
az keyvault show `
  --name "lab3-kv-tr2zcmzyzzlno4" `
  --resource-group lab3-rg `
  --query "{RBAC:properties.enableRbacAuthorization,
PurgeProtection:properties.enablePurgeProtection,
NetworkDefault:properties.networkAcls.defaultAction,
SoftDeleteDays:properties.softDeleteRetentionInDays}" `
  -o table
```

RBAC	PurgeProtection	NetworkDefault	SoftDeleteDays
True	True	Deny	7

✅ **CONFIRMED OK**

RBAC: True. NetworkDefault: Deny. PurgeProtection: True. Soft delete documented as deployment-time finding.

PHASE 6 — DIAGNOSE + FIX · PROBLEM 3: MFA GAP

13

Check Conditional Access Policies in Entra Admin Center

PROBLEM

Navigation: entra.microsoft.com → Protection → Conditional Access → Policies

Policy Name	State	Created
-----	-----	-----
Require-MFA-All-Users	Report-only	5/2/2026

❑ PROBLEM CONFIRMED

Policy exists but State is Report-only. Report-only = monitoring only, not enforcing. MFA is not required for anyone. Three suspicious sign-in attempts detected during this window.

14

Disable Security Defaults

PASS

Required before custom CA policies can be enabled.

Navigation: entra.microsoft.com → Identity → Overview → Properties → Manage security defaults

Security defaults: Disabled
Reason: My organization is planning to use Conditional Access

15

Enable Conditional Access Policy

PASS

Navigation: Conditional Access → Require-MFA-All-Users → Enable policy → On → Save

Policy Name	State	Modified
-----	-----	-----
Require-MFA-All-Users	On	5/23/2026

✅ CONFIRMED OK

Policy state changed from Report-only to On. MFA now enforced for all users including guests. Security Defaults disabled and replaced with Conditional Access.

PHASE 7 — CLEANUP

```
# Delete service principal
$spAppId = az ad sp list --display-name "lab3-webapp-sp" --query
"[0].appId" -o tsv
az ad app delete --id $spAppId

# Delete resource group
az group delete --name lab3-rg --yes --no-wait

# Delete insecure credentials file
Remove-Item .\sp-credentials.txt -Force
```

COMMAND REFERENCE — QUICK LOOKUP

Purpose	Command
List all roles for an identity	<code>az role assignment list --assignee <id> --all</code>
Remove a role	<code>az role assignment delete --assignee <id> --role "<name>" --scope <scope></code>
Assign a role	<code>az role assignment create --assignee <id> --role "<name>" --scope <id></code>
Get Key Vault security settings	<code>az keyvault show --query "{RBAC:..., Network:...}"</code>
Enable RBAC on Key Vault	<code>az keyvault update --enable-rbac-authorization true</code>
Lock Key Vault network	<code>az keyvault update --default-action Deny --bypass AzureServices</code>
List service principals	<code>az ad sp list --display-name "<name>"</code>
Get SP App ID into variable	<code>\$spAppId = az ad sp list --display-name "<name>" --query "[0].appId" -o tsv</code>
Get Key Vault resource ID	<code>\$kvId = az keyvault show -g <rg> -n <name> --query id -o tsv</code>
List all resources in RG	<code>az resource list --resource-group <rg> --output table</code>
Delete an app registration	<code>az ad app delete --id <appId></code>